

Network Infrastructure Design – Cybersecurity

Capstone Project

Midsized Professional Services Firm
Final Project Document – Stage 1
Date: November 2025

Project Summary (Executive Overview)

Objective:
Design and document a secure, scalable, and compliant enterprise network infrastructure aligned with the NIST CSF 2.0 and Zero Trust Architecture (ZTA) principles.

Scope:
Covers core, distribution, access, and security layers, along with virtualization, segmentation (16 VLANs), and cloud + on-prem hybrid integration.

- Key Deliverables:**
- End-to-end network topology diagram (Core → DMZ → Access)
 - IP addressing plan and VLAN segmentation matrix
 - Hardware + software inventory with capacity planning
 - Security control mapping (NIST CSF / MITRE ATT&CK)
 - Risk & mitigation framework (Top 3 network risks)

Project Metrics (Quick Snapshot)

Metric	Value
Total VLANs	16
Total Devices	~700 (servers, workstations, phones, IoT, APs)
Current Users	~100 employees
Projected Growth	+75 (50–75% increase)
Total Servers (Physical + VMs)	~180 (15 hosts + 165 VMs)
Storage Capacity	~794 TB usable
Internet Links	2 (ISP Fiber + 5G Failover)
Compliance Baseline	GDPR / ISO 27001 / SOC 2 (planned)

Design Highlights

- Zero-Trust VLAN Segmentation: Departmental isolation across 16 VLANs.
- High Availability: pfSense HA firewall cluster + dual ISP.
- Visibility & Detection: Wazuh EDR + Elastic SIEM + LibreNMS monitoring.

- Resilience: Ceph storage cluster + NAS + AWS S3 Glacier backup.
- Governance: Change management and CIS benchmark hardening across assets.

Document Ownership

Role	Name / Team
Prepared By	Prageeth Panicker
Reviewed By	IT & Security Team
Approved By	[Supervisor / Instructor / Client Rep]

Key Deliverables

1. Gather Requirements
 - Interviewed stakeholders and analyzed business, performance, and security needs.
 - Captured all inputs in the Customer Requirement Traceability Matrix and Executive Summary.
2. Choose & Justify a Framework
 - Evaluated NIST CSF 2.0 and MITRE ATT&CK frameworks.
 - Selected NIST CSF 2.0 as the guiding model; provided rationale and mapped controls across all six functions.
3. Draw Logical Topology
 - Developed the complete End-to-End Network Diagram (Core → DMZ → Access).
 - Illustrated traffic flow, redundancy, and segmentation across 16 VLANs.
4. Design IP Scheme
 - Defined subnets, gateways, and DHCP scopes for each VLAN.
 - Produced the IP Addressing Plan and VLAN Segmentation Matrix for all departments.
5. Compile Inventory
 - Created a detailed Hardware and Software Inventory with specifications, roles, and capacity planning.
6. Risk Assessment
 - Conducted a Top 3 Network Risk analysis (Misconfiguration, Unauthorized Access, Insider Threat).
 - Documented mitigation measures mapped to NIST CSF controls and recovery procedures.

1. Customer Requirement Traceability Matrix

Req ID	Category	Stakeholder	Business Requirement	Technical Translation	Design Component / Solution	Verification Method	Dependencies	Implementation Notes / Cost Impact	Priority	Status
FR-001	Business Context	Alex (CIO)	We're a 100-employee professional services firm offering IT modernization, cloud migration, and data analytics. Need reliable, secure, efficient infrastructure for both on-site and remote teams.	Network must support consulting operations with hybrid work model; enable client project delivery without disruption	Proxmox-based hybrid network, VLAN segmentation [5/10/30/60], pSense HA firewall pair, dual ISP, Wazuh SIEM for uptime monitoring	Verify hybrid connectivity (on-site + VPN), check CARP failover, confirm remote access via VPN and performance monitoring dashboards.	None	Foundation requirement for all network design decisions. Defines business context and operational model.	Critical	Planned
FR-002	Business Continuity	Alex (CIO)	If our internal network or systems go down—even briefly—monthly sales, internal tools (Billing, HR), and client outage could stall deliverables and cause us to miss client deadlines.	Critical systems require 99.95% uptime; downtime tolerance <15 minutes/month for client-facing systems	Dual-ISP (Fiber + 5G), HA pSense (CARP), redundant Core switches (VRRP), Wazuh alerting <5min.	Simulate WAN failover and verify secondary ISP takeover <30s; observe SIEM alerts in Wazuh dashboard.	FR-001, FR-011	€18K/year dual ISP cost justified by €7,500/hour outage cost (FR-005). Annual ISP cost = 2.4 hours of prevented downtime.	Critical	Planned
FR-003	System Architecture	Alex (CIO)	Client Portal integrates with internal auth, PM Platform syncs with scheduling/timesheets, Secure File Exchange depends on permissions, Billing Dashboard pulls from finance platform.	Four critical systems with interdependencies: Client Portal, PM Platform, File Exchange, Billing Dashboard must isolate to prevent cascading failures	VLAN segmentation, DMZ isolation; HAProxy [10.5.0.19–21]; DB tier on 10.30.0.10–13; Nginx/Apache web tiers.	Attempt inter-segment access and confirm ACL blocks; review firewall logs and HAProxy routes.	FR-001, FR-016, FR-041	Zero-trust segmentation prevents cascading failures. Each system can fail independently without affecting others.	Critical	Planned
FR-004	Peak Concurrent Users	Alex (CIO)	At peak hours, 60-70% of workforce is remote (60-70 people online at once). Nearly all touch Client Portal or PM Platform. Geographic diversity means peak stretches over several hours.	Network must handle 70 concurrent remote users without lag; plan for 100-120 concurrent as we scale	OpenVPN HA cluster [10.0.0.125–126], QoS for Zoom/Slack; 1 Gbps fiber.	Run 100-session VPN load test; verify throughput, latency, and QoS markings (DSCP) on WAN.	FR-002, FR-023, FR-037	2 Gbps fiber supports 100 concurrent VPN users @ 10 Mbps each. Future: upgrade to 2 Gbps if needed.	Critical	Planned
FR-005	Downtime Tolerance	Alex (CIO)	Client-facing systems: less than 15 minutes per month, ideally zero. Internal tools (Billing, HR) up to 2-4 hours per month if scheduled and communicated.	Tiered availability requirements: Tier 1 (client-facing) 99.95%, Tier 2 (internal) 99.5%	Tier1: Dual ISP + pSense HA + core redundancy; Tier2: planned maintenance windows and rollback.	Review uptime reports per tier; run planned maintenance and confirm Tier1 unaffected.	FR-002, FR-011	Tier 1: 2.1 min/month max downtime. Tier 2: 2.1 hr/month allowable with notice.	Critical	Planned
FR-006	Outage Cost Impact	Jordan (CFO)	One hour outage during business hours: \$7,500 in lost billable revenue (10 delivery staff @ \$150/hr), plus potential SLA penalties ranging from hundreds to thousands of dollars per breach.	Infrastructure investment must be justified by outage cost avoidance; redundancy ROI is positive	HA firewalls, redundant core, Ceph replication; alerting via Wazuh.	Compare prevented downtime vs spend; validate via incident & uptime logs.	FR-002, FR-007	Annual redundancy cost ~€50K justified by preventing 7+ hours downtime/year. ROI positive after Year 1.	Critical	Planned
FR-007	Budget Allocation	Jordan (CFO)	Budget estimate: €60,000-€165,000 initial deployment (roughly \$100,000 midpoint). Prefer \$100K as benchmark with flexibility to scale up if vendor quotes require more.	Implement best-in-class solution without strict budget constraints; focus on business value and long-term ROI rather than initial capital limitations	Open-source core (Proxmox, pSense, Wazuh) + Duo MFA; enterprise where justified.	Finance review of BOM vs features; check licensing and TCO worksheet.	None	Open-source software saves €414K/year vs commercial (€1.24M over 3 years). MFA only paid license at €6K/year.	Critical	Planned
FR-008	CapEx vs OpEx	Jordan (CFO)	Prefer higher upfront investment in core infrastructure (VPN, firewalls, auth) for predictable ownership. Open to OpEx subscription for specialized security/monitoring. Avoid leasing—want clean books.	CapEx-heavy for core network infrastructure; OpEx for cloud services and monitoring tools	Servers/switches as CapEx; ISP/MFA/SaaS/SIEM cloud as OpEx.	Audit GL categorization; confirm contracts & depreciation schedule.	FR-007	CapEx: €895K (3-year total: €1.23M). OpEx: €1.18K/year. Commercial equivalent: €2.38M (saves €930K over 3 years).	High	Planned
FR-009	Cost Optimization	Jordan (CFO)	Need cost-effective solutions with minimal waste. No overbuilding, but sufficient capacity to prevent disruption. Right-sized for 60 users, scalable to 100.	Implement properly-sized infrastructure with growth headroom; avoid underprovisioning that leads to future replacement costs	15 Proxmox hosts; Ceph 20 nodes; modular VLANs; scalable VPN user licenses.	Monthly capacity reports (CPU/RAM/ports/DHCP scopes/VPN); alert at 80%.	FR-007, FR-020	Current utilization: 50% employees, 65% servers, 6% IPs. Headroom for 100% growth without hardware refresh.	High	Planned
FR-010	Financial Risk Mitigation	Jordan (CFO)	Must avoid financial penalties, insurance risks, and data breaches. Security controls should reduce financial exposure without excessive cost.	Implement security controls that reduce financial risk; align with cyber insurance requirements	Wazuh+ELK SIEM; PCI-DSS segmentation, MFA everywhere; IR playbooks.	Quarterly control audits; SIEM rule tests; phishing+IR tabletop.	FR-038, FR-031, FR-032	Security controls meet cyber insurance requirements. Wazuh EDR €0 vs CrowdStrike €30K/year.	Critical	Planned
FR-011	Operational Uptime	Casey (COO)	More than 15 minutes of downtime per month affects SLAs with customers and internal productivity. Tech needs to 'just work'.	Target 99.95% uptime (21 minutes downtime/month max); focus on operational resilience	Dual-ISP, pSense CARP, VRRP core, UPS on racks, Wazuh/Ubiquiti monitoring.	Pull monthly uptime SLA report; simulate link, firewall, and switch failure; verify alert in <5 min.	FR-002, FR-005	Monitoring detects issues <5 min. Auto-failover <30s. Target: zero unplanned downtime/month.	Critical	Planned
FR-012	Collaboration Tools	Casey (COO)	Daily tools: Slack, Zoom, PM Platform (Monday.com/Jira), Google Workspace. All cloud-hosted. Must work flawlessly across time zones (Pam-Jon CET overlap). VPN must not throttle real-time traffic.	Cloud collaboration tools require reliable connectivity with QoS; no VPN throttling for voice/video	WPA3-Enterprise Wi-Fi; QoS DSCP EF/AF; split tunneling for Zoom/Slack/Workspace.	Packet-capture DSCP marks; speed tests during calls; verify split-tunnel routes.	FR-040	QoS: Voice EF (DSCP 46), Video AF41 (DSCP 34). Priority 7 for VoIP. Split-tunnel reduces VPN load by 60%.	High	Planned
FR-013	Consultant Dual-Access	Casey (COO)	Consultants connect directly to client environments via client VPN, but also VPN into our network for internal resources. Dual-access model requires clear network segmentation to avoid IP conflicts and traffic routing issues.	Support dual VPN access model; prevent traffic conflicts between internal and client networks	Unique IP ranges; per-role VPN profiles; route exclusions; logging.	Connect to client VPN + internal VPN; traceroute to confirm path; check logs for conflicts.	FR-037	Internal VPN: 10.0.0.0/8. Exclude client ranges (typically 192.168.x.x, 10.x.x.x) from routing table.	High	Planned
FR-014	Consultant Workflow	Casey (COO)	9-step milestone delivery: (1) Slack/Zoom sync, (2) PM tool updates, (3) Access shared files, (4) Reference internal wikis, (5) Upload to Secure Exchange, (6) Client review call. 30-60 min downtime throws off timelines.	All workflow systems must be highly available; implement offline fallbacks where possible	Nextcloud/Share caches; auto-save; secondary access to PM; emergency comms tree.	Unplug WAN; confirm cached file access; test SaaS comms; validate PM secondary access.	FR-002, FR-011	Offline mode: Nextcloud sync client provides 4-hour local cache. PM platform has mobile offline access.	High	Planned
FR-015	IoT Device Segmentation	Casey (COO)	Security cameras (IP-based), door access (cloud-managed), networked printers (Admin/Finance/HR), building management (HVAC). Must be isolated from business systems. Logs may contain PII under GDPR.	IoT devices require dedicated VLAN with no access to internal business systems	VLAN 70 IoT; ACL blocks to Staff; only mgmt reachability; NAC profiling.	Attempt IoT→Staff access (should fail); verify NAC profiles; internet blocked (except whitelisted cloud).	FR-036, FR-041	120 IoT devices: 30 cameras, 20 access control, 20 HVAC, 50 misc. Zero trust - management VLAN only.	High	Planned
FR-016	Database Infrastructure	Casey (COO)	Billing Dashboard (on-prem) requires database server. Internal wikis, project data, and QA environments also need database support. Currently deployed in VLAN 30.	On-premise database server(s) for business-critical applications with backup and replication	PostgreSQL/MySQL on VLAN 30; daily backups to NAS; replication to standby.	Restore-from-backup test; failover test; check TLS at rest/in-transit config.	FR-022	10 PostgreSQL instances, 6 MySQL instances. PostgreSQL 16 chosen over Oracle (saves €40K/year licensing).	Critical	Planned
FR-017	Management Network	Casey (COO)	Need dedicated management VLAN for infrastructure devices (firewalls, switches, VPN concentrators, SIEM, monitoring). Currently implemented as VLAN 10 with 64 servers.	Isolated management network for administrative access to infrastructure	VLAN 10 Mgmt (64 servers); bastion host; AD/LDAP; Wazuh/ELK; NAC; no direct internet.	Attempt direct internet from Mgmt (should fail); verify jump-box only access; review routing/ACLs.	FR-036, FR-041	VLAN 10: 64 mgmt servers including Wazuh, J1K, OpenCTI, network forensics, RADIUS, switch mgmt. Jump-box only access.	Critical	Planned
FR-018	24/7 Monitoring	Casey (COO)	Network issues require real-time detection (5 minutes max). Tiered alerting: P1 immediate (outage/breach), P2 30min (degradation), P3 next business day. Alerts via PagerDuty + Slack.	Comprehensive network monitoring with tiered alerting and automated escalation	LibreNMS/ELK; PagerDuty + Slack; on-call rotation integration.	Trigger test alarms (P1/P2); verify escalation timelines; audit alert receipts.	FR-038, FR-039	LibreNMS + Wazuh + €0 vs SolarWinds NPM €8K/year. Monitoring all 700+ devices and 162 VMs.	High	Planned
FR-019	Operational Dashboards	Casey (COO)	Need: Network topology map (live status), bandwidth usage by VLAN, VPN user list, total talkers, application performance. Accessible via web portal and mobile app. PMs need visibility.	Real-time operational dashboards with role-based access	Executive/Operations/Security dashboards in Kibana/Grafana; VPN + NetFlow panels.	Log in with different roles; verify widgets availability; check mobile view.	FR-018, FR-036	Kibana/Grafana dashboards + €0 vs Splunk Enterprise €60K/year. RBAC for 5 role types.	Medium	Planned
FR-020	Capacity Planning Metrics	Casey (COO)	Track: Bandwidth trends (approaching 50 Gbps?), VPN user growth (approaching capacity?), switch port utilization, storage usage, DHCP scope exhaustion.	Automated capacity monitoring with growth projections and alerting	Grafana/LibreNMS trends; DMCF - 80% alerts; VPN usage tracking; storage forecasts.	Review monthly capacity report; confirm notifications at thresholds.	FR-009, FR-018	Current: 50% employee capacity, 65% server capacity, 6% IP utilization. Alerts at 80% thresholds.	High	Planned
FR-021	Change Management	Casey (COO)	All network changes require: IT lead approval for routine changes, security team + CDO approval for major changes. Document in change tickets with version control. After hours change windows. Rollback plan required.	Formal change management process with approval workflows and documentation	FSM tool; approval matrix; pre-change Checklist backups; rollback procedures.	Sample change: push config; verify pre/post backups; approvals present; rollback test.	FR-022	Devized auto-backups all 32 switches + 4 firewalls daily. Version control via Git. Zero-cost vs SolarWinds NCM €6K/year.	High	Planned
FR-022	Config Backup & DR	Casey (COO)	Network device configs backed up daily, after every change. Store locally + cloud. RTO for network infrastructure: 4 hours. Automated backups mandatory, not manual.	Automated configuration backup with rapid restoration capability	Devized/scripts daily; NAS + EU cloud storage; monthly restore tests.	Delete dummy config and restore; check version history and retention.	FR-029	36 network devices auto-backed up: 32 switches, 4 firewalls. 90-day retention. EU-only storage (GDPR).	Critical	Planned
FR-023	Workforce Growth	Riley (HR)	Projecting growth from 100 to 150-175 employees over 2-3 years. 70% remote, 30% office/hybrid. Growth mainly in Delivery, Customer Success, Sales. Peak VPN usage will hit 100+ concurrent.	Network must support 50-75% growth; plan for 150-175 users with 100-120 concurrent VPN sessions	VPN licenses 150/120 concurrent; DMCF scopes with 50% headroom; 2+ bandwidth.	Count licenses; simulate 120 concurrent; verify DHCP free addresses; check ISP bandwidth graphs.	FR-004, FR-029	Current: 100 employees, 70 concurrent VPN. Capacity: 200+ employees, 120+ concurrent. 100% growth headroom.	High	Planned
FR-024	Geographic Distribution	Riley (HR)	Current: 30 office (Düsseldorf), 30 remote Germany, 20 remote EU, 20 remote US/UK/Other. Projected: 40-50 office, 35-45 remote Germany, 30-35 remote EU, 30-35 remote international.	Support multi-region access with regional VPN endpoints and compliance considerations	Primary EU VPN; optional US profile; geo-policies; latency optimization.	Test from EU/US; compare latency; verify regional policy enforcement and logs.	FR-029	EU VPN (Düsseldorf): <20ms Germany, <50ms EU, <120ms US. GDPR data residency enforced.	High	Planned
FR-025	Plug-and-Play Access	Riley (HR)	Most new hires are not technical. Need plug-and-play VPN and auth [15-30 min setup max]. App-based MFA (Duo, Okta verify). Automated VPN client provisioning. Support BYOD with simple policies.	User-friendly authentication with minimal IT support required	MDM + auto-provision VPN profiles; Duo push; BYOD policies.	New user dry-run; measure setup time; verify MFA and device enrollment.	FR-026, FR-027	Duo MFA: €6K/year for 100 users. OpenVPN client auto-provision via MDM. 15-min new hire setup target.	High	Planned
FR-026	Day 1 Access by Role	Riley (HR)	Consultant Day 1: VPN+MFA, PM Platform, Slack/Zoom, Google Workspace, wikis, limited QA/Testing. PM Day 1: All consultant access + full PM permissions + Billing (read-only). Finance Day 1: VPN restricted, Billing (full), Finance shared drives.	Role-based access provisioning from Day 1 with pre-approved templates by job title	Templates: Consultant/PM/Finance/HR/IT; MFA enforced; logging.	Create test users per role; verify access matrix; check audit trails from first login.	FR-032, FR-037	5 role templates: Consultant, PM, Finance, HR, IT. AD groups auto-provision based on job title in HR system.	High	Planned

Customer Requirement Traceability Matrix (Cont.)

FR-027	Rapid Offboarding	Riley (HR)	Access revocation within 1 hour of termination notification. Disable VPN, email, Slack, PM tools, File Exchange, HR/payroll systems. Remote wipe for BYOD. Audit logs retained 12-18 months. Contractors often get missed—same rigor applies.	Automated offboarding with immediate access revocation	Workflows to disable VPN/Email/Slack/PM, MDM lock/wipe; email forward; log retention.	Fire a test account; measure time to revoke; verify device wipe and log retention.	FR-025, FR-030	Target: <1 hour offboarding. Automated workflow disables all access. 12-month log retention for audit trail.	Critical	Planned
FR-028	Multi-Regulatory Compliance	Morgan (Compliance)	Must comply with GDPR (all EU clients/data), HIPAA-like (healthcare clients/PHI), PCI DSS (select finance clients). Each requires different controls: data minimization, encryption, segmentation, audit logging.	Network design must support multiple compliance frameworks simultaneously	Segmented VLANs; encryption; MFA; annual pentests; audit logging.	Review policy-to-control mapping; pentest report; encryption and MFA evidence.	FR-029, FR-030, FR-031	Compliance frameworks: GDPR, HIPAA-like, PCI DSS, ISO 27001 (in progress), SOC 2 (2026). Zero-cost open-source meets requirements.	Critical	Planned
FR-029	Data Residency	Morgan (Compliance)	All GDPR-covered client data must reside in EU or be governed by SCCs. Healthcare data (HIPAA-like) must stay in approved regions (EU or US as contracted). HR/payroll data strictly EU-local. All cloud vendors must support EU regional storage.	Enforce data residency requirements through technical and contractual controls	EU regions for Google Workspace/Secure Exchange/SEM; on-prem DB; vendor DPA/SCCs.	Vendor console screenshots of EU regions; DB on-prem check; DPA/SCC file review.	FR-032, FR-022	All data EU-resident: Servers (Disselhorst), Google Workspace (EU), Wazuh/ELK (EU), DPAs signed with all vendors.	Critical	Planned
FR-030	Audit Logging	Morgan (Compliance)	Detailed audit trails required: user access logs, admin activity, data transfers, authentication events, system changes, email metadata (sender/time/recipients). Retention: 12-18 months minimum. Logs must be tamper-proof.	Comprehensive logging with immutable storage and long retention	Wazuh/Elastic; object lock/WORM on backups; auth/admin/data-transfer logs.	Generate sample events; verify retention settings; test immutability (write once).	FR-028, FR-031	160+ Wazuh agents. 90-day Elasticsearch retention. 12-month archive to NAS with WORM. Zero-cost vs Splunk €60K/year.	Critical	Planned
FR-031	ISO 27001 & SOC 2	Morgan (Compliance)	ISO 27001: In Progress. SOC 2 Type I/II Planning 2026. Requires: centralized logging, RBAC, change management, documented policies, MFA for remote/admin access, DLP monitoring, recovery workflows.	Network and security controls must align with ISO 27001 Annex A and SOC 2 Trust Service Criteria	RBAC in all systems; change mgmt; MFA on admin; DLP for cloud; recovery runbooks.	Control audit using checklist; evidence exports; mock audit session.	FR-026, FR-030	ISO 27001 target: Q4 2026. SOC 2 Type I: Q2 2026. All technical controls already implemented.	Critical	Planned
FR-032	Security Monitoring	Morgan (Compliance)	Monitor: failed authentication attempts (VPN/Wifi/watch mgmt), unusual traffic patterns, firewall rule violations, rogue devices, configuration changes. Real-time alerts for P1 (critical), daily reports for informational.	Advanced security monitoring with threat detection and alerting	Wazuh rulesets; Firewall AAA logs; rogue device detection; config change webhooks.	Simulate failed logins & port scans; verify alerts and ticket creation.	FR-018, FR-045	Wazuh monitors 150k+ endpoints + 3k network devices. 50K+ IPS rules (Snort). Real-time alerting <5 min.	Critical	Planned
FR-033	Vulnerability Management	Morgan (Compliance)	Scan network devices monthly for vulnerabilities. Critical vulnerabilities: 7-day patching timeline. Maintenance windows for production devices required. Vulnerabilities that can't be patched immediately require compensating controls.	Formal vulnerability management program with defined timelines	Monthly scanning schedule; patch pipelines; compensating controls tracking.	Run scans; verify SLA dashboards; sample critical patch within 7 days.	FR-034	OpenVAS 90K+ vulnerability tests. Zero-cost vs Nessus €1.5K/year or Qualys €8K/year. Monthly scans all 700+ devices.	High	Planned
FR-034	Network Hardening	Morgan (Compliance)	Enforce baselines: Disable unused services/ports, change default credentials, strong password policies, disable insecure protocols (Telnet/HTTP/SNMPv1+v3), enable logging, use SSH keys for admin access. Use CIS Benchmarks.	Network device hardening based on industry standards (CIS Benchmarks)	SNMPv3 only, SSH/HTTPS mgmt, disable Telnet/HTTP, key-based admin; logging enabled.	Automated config audit (CIS benchmark script); spot-check devices; remediate drift.	FR-033, FR-044	CIS Benchmarks for: Ubuntu 22.04, pSense, switches, SNMPv3 only, SSH key-based auth, no Telnet/HTTP	High	Planned
FR-035	Network Forensics	Morgan (Compliance)	Need forensics for: Data breach (what data left?), compromised VPN (what did attacker access?), malware outbreak (lateral movement?), insider threat (user activity tracking). Capabilities: NetFlow/PPPoE, metadata capture, 90-day historical query.	Network forensics capabilities for incident investigation	NetFlow from core; DHCP logs; Elastic queries; privacy by design (metadata only).	Backfill 90 days; reconstruct session via logs; verify GDPR-compliant scope.	FR-046	NetFlow on 8 core switches. 90-day retention in Elasticsearch. Metadata-only (GDPR compliant). Network Forensics server: 10.0.0.109.	High	Planned
FR-036	Network Access Control	Morgan (Compliance)	NAC requirements: Device registration (only known devices join network), guest device isolation (auto VLAN assignment), endpoint health checks (AV updated, OS patched), quarantine VLAN for non-compliant devices. BYOD treated differently than corporate.	NAC implementation with health checks and dynamic VLAN assignment	EAP-TLS for corp; MAC mgmt; quarantine VLAN 10.0.0.0/24; BYOD SSID.	Onboard compliant device; block non-compliant to quarantine; guest internet only test.	FR-048	FreeRADIUS (10.0.0.65) provides NAC. 802.1X EAP-TLS for corporate. MAC-based for guest. Quarantine VLAN auto-assigned.	High	Planned
FR-037	VPN Role-Based Profiles	Casey (COO)	Five VPN profiles: Consultant (PM Platform, File Exchange, SA), PM (adds billing read-only), Executive (adds billing full access), HR (HRIS, Payroll), IT Admin (all VLANs). MFA required for all. Session timeouts vary by role.	Granular VPN access based on job function with appropriate restrictions	OpenVPN with per-profile ACLs; MFA (Duo); role-based timeouts and geo-restrictions.	Connect each profile; validate reachable systems; confirm timeouts and geo blocks.	FR-013, FR-026, FR-041	5 VPN profiles mapped to AD groups. Consultant: 8hr timeout. IT Admin: 2hr timeout. All require Duo MFA.	High	Planned
FR-038	Monitoring Platform Selection	Casey + Morgan	Prefer cloud-hosted monitoring for easier remote access. Accept open-source (Wazuh, ELK) if well-supported. Must include: encryption at/in transit, RBAC, audit logging, EU data residency. Export configs locally for DR.	Cloud-based monitoring with on-prem backup; open-source preferred with managed support	Cloud LibreNMS/enterprise tool; Wazuh+ELK (EU); local NAS export of configs/logs.	Confirm EU residency; export configs; simulate cloud outage and use local exports.	FR-016, FR-029	Wazuh+ELK stack + €D/year vs Splunk €60K/year or Datadog €8K/year. EU-hosted, daily local backups.	Critical	Planned
FR-039	Monitoring Budget	Jordan (CO)	Three budget tiers: Minimal (€5K-€10K + €1K-€5K/yr open-source self-hosted), Moderate (€15K-€30K + €5K-€10K/yr commercial), Comprehensive (€30K-€50K + €10K-€20K/yr enterprise). Recommend Moderate tier for balance.	Select monitoring platform based on operational needs and capabilities rather than cost; prioritize features, scalability, and vendor support	Enterprise platform incl. support/training; managed services; AI insights.	Validate contract scope; check SLAs; pilot features meet ops needs.	FR-007, FR-038	Selected: Open-source (Wazuh/ELK/LibreNMS) €D/year vs Enterprise €20K/year. Saves €60K over 3 years.	High	Planned
FR-040	QoS & Traffic Prioritization	Casey (COO)	Traffic priorities: High (Zoom/Video, PM Platform, Client Portal), Medium-High (File Exchange uploads), Medium (Google Drive), Low (printer/scanner, guest WiFi, system patching). Voice/Video marked as real-time.	Implement QoS policies to ensure business-critical applications get priority	EF for voice, AF41 video, AF31 PM/Portal, AF21 file, BE default, CS3 scavenger.	QoS policy audit on switches/firewalls; packet capture to confirm DSCP; synthetic call tests.	FR-012	QoS Classes: Voice EF (DSCP 46), Video AF41 (DSCP 34), PM AF31 (DSCP 26), VoIP phones priority 7.	High	Planned
FR-041	VLAN-Based Firewall Rules	Morgan (Compliance)	Detailed ACLs per VLAN; Mgmt (IT only, no internet), Remote-VPN (RBAC-based access), Staff (Internet + internal apps, no IoT), Guest (Internet only, IoT Mgmt only for monitoring, no internet), SecureFileExchange (VPN + authorized staff).	Implement least-privilege firewall rules based on VLAN segmentation	pSense rulesets: Mgmt no internet; VPN RBAC; Guest internet only; IoT only to Mgmt; SFE to VPN/staff only.	Attempt disallowed paths; review firewall logs; export ruleset for evidence.	FR-003, FR-015, FR-017, FR-037	16 VLANs with custom ACLs. Zero-trust model: pSense manages 500+ firewall rules. Tested monthly.	High	Planned
FR-042	CASB & SASE	Alex (CISO)	Integrate CASB (Cloud Access Security Broker) and SASE (Secure Access Service Edge) as part of modern cloud security architecture. Implement now as cloud adoption is current, not future.	Implement cloud-native security architecture with CASB and SASE components	Cloudflare One (ZTNA, SWG, CASB) pilot; identity-based access; SD-WAN readiness.	Enable pilot; verify app discovery/DLP; test ZTNA app access; review metrics.	FR-010	Cloudflare One pilot: €7K-14K/year for 100 users. Provides CASB, ZTNA, SWG in single platform.	High	Planned
FR-043	Security Framework	All Stakeholders	Unanimous support for NIST CSF 2.0 (Govern-Identify-Protect-Detect-Respond-Recover) as primary framework, informed by MITRE ATT&CK for threat-based controls. Provides executive communication clarity, tactical defense, and audit alignment.	Implement NIST-led, MITRE-informed hybrid security strategy	NIST CSF profiles (current+target); MITRE mapping to SEM rules; maturity roadmap to Tier 3 (18 months).	Publish profiles; run gap assessment; track quarterly maturity KPIs.	FR-010, FR-026, FR-031	NIST CSF 2.0 framework with MITRE ATT&CK threat modeling. Target: Tier 3 maturity by Q4 2026.	Critical	Planned
FR-044	Switch Infrastructure	Casey (COO) + Morgan	Need robust switching infrastructure to support 100+ users across core, distribution, and access layers with proper redundancy, management, and security features. Must support PoE+ for wireless APs and VoIP phones.	32 managed switches (8 Core L3, 6 Distribution L3, 18 Access L2) with PoE+, stacking, VRRP, 802.1X authentication, and centralized management	Core: 8xL3 (48x1G PoE+, 10G uplinks, VRRP). Distribution: 6xL3 (24x1G, 10G); Access: 18xL2 (24x1G PoE+, 2x10G uplink); NetFlow v9; 802.1X port auth.	Verify switch stack operation; test VRRP failover; validate 802.1X port authentication; check PoE+ power budget; confirm NetFlow export to collector.	FR-017, FR-034, FR-036, FR-047, FR-048	32 switches total. Core switching capacity: 2 Tbps. PoE+ budget: 370W per access switch. Cost: ~€7K-€194K hardware.	Critical	Planned
FR-045	Threat Intelligence Platform	Morgan (Compliance)	Need proactive threat intelligence to detect emerging threats, coordinate incident response across security tools, and maintain situational awareness. Must integrate with SIEM, Firewall, and IPS/IDS for automated response.	OpenCTI platform for threat intelligence aggregation, analysis, correlation, and automated response coordination with existing security stack	OpenCTI HA cluster (10.0.0.110-111) integrated with Wazuh/SEM, pSense (pfBlockerNG), and Snort/Suricata IPS/IDS; automated IoC blocking; MITRE ATT&CK mapping	Import threat feeds (MISP, AlienVault OTX); verify automatic IoC blocking on firewall; test incident response workflow; validate MITRE ATT&CK mapping in dashboards.	FR-032, FR-043	OpenCTI: €D vs Anomali ThreatStream €40K/year. Integrates with Wazuh, pSense, Snort. MITRE ATT&CK native support.	High	Planned
FR-046	Network Forensics & Packet Capture	Morgan (Compliance)	Need ability to conduct deep packet analysis for security investigations, incident response, and compliance audits. Must support full packet capture on critical network segments with 7-day retention while maintaining GDPR compliance.	Dedicated network forensics server with packet capture capabilities, 7-day retention, and privacy-by-design architecture for GDPR compliance	Network Forensics server [10.0.0.109] with SPAN/Mirror ports on core switches. WireShark/burp for capture; Zeek for protocol analysis; 7-day retention; metadata-only for privacy	Capture traffic on critical segments; reconstruct TCP sessions; verify 7-day retention; confirm metadata-only logging (no payload inspection except authorized investigations); test GDPR compliance.	FR-035, FR-029	Server: 10.0.0.109. Captures from core switches via SPAN. 7-day full PCAP on DMZ/Management. Metadata-only on user VLANs (GDPR).	High	Planned
FR-047	Switch Management Infrastructure	Casey (COO)	32 managed switches require centralized management, monitoring, automated configuration backup, firmware updates, and performance tracking. Must integrate with change management process and provide single pane of glass visibility.	Dedicated switch management infrastructure for SNMP monitoring, automated config backup (Oxidized), centralized provisioning, and performance analytics	Switch Management cluster (10.0.0.119-179): 3 servers for Oxidized (config backup), LibreNMS (SNMP monitoring), and automation scripts. Git backend for version control; daily backups; firmware repository	Verify automated config backups after changes; test config restore process; validate SNMP monitoring dashboards; check firmware update workflow; confirm Git version control	FR-018, FR-021, FR-044	3 management servers. Monitors 32 switches. Dedicated auto-backup daily. LibreNMS SNMP monitoring. Zero-cost vs SolarWinds NCM €6K/year.	High	Planned
FR-048	RADIUS Authentication Infrastructure	Morgan (Compliance)	802.1X port-based network access control required for all wired and wireless connections. Must support EAP-TLS for corporate devices, MAC-based authentication for guests, and integrate with Active Directory for user authentication.	FreeRADIUS server providing AAA services for 802.1X authentication across switches and wireless infrastructure with AD/LDAP integration	FreeRADIUS server (10.0.0.65) integrated with AD (10.0.0.20-29); EAP-TLS for corporate (certificate-based); MAC auth for guests; dynamic VLAN assignment; logging to Wazuh; redundancy via secondary RADIUS	Test 802.1X authentication on wired ports; verify wireless EAP-TLS; validate certificate chain; test MAC-based guest auth; confirm dynamic VLAN assignment; verify quarantine VLAN for non-compliant devices	FR-036, FR-044	FreeRADIUS: €D vs Cisco ISE €20K/year. 802.1X on all 32 switches + WiFi. EAP-TLS certificate-based auth for security.	Critical	Planned

2. Framework Justification

Our organization will adopt a hybrid framework approach, using NIST Cybersecurity Framework (CSF) 2.0 as our primary strategic framework, supplemented by MITRE ATT&CK for tactical threat intelligence and detection engineering.

Primary Framework: NIST CSF 2.0

NIST CSF 2.0 provides the comprehensive, business-aligned structure our organization needs. With its six core functions (Govern, Identify, Protect, Detect, Respond, Recover), it aligns directly with our ISO 27001 and SOC 2 certification goals—critical for client procurement requirements. The framework's sector-neutral approach accommodates our diverse client base across healthcare, finance, and general consulting.

The newly added "Govern" function addresses our CEO's emphasis on business-aligned security and our CFO's need for risk-based resource allocation. NIST CSF's Organizational Profiles enable us to define current and target security postures, supporting our phased implementation roadmap. The framework's high-level outcomes facilitate executive communication while providing sufficient detail for technical implementation.

Supporting Framework: MITRE ATT&CK

MITRE ATT&CK complements NIST CSF by providing tactical threat intelligence for our SOC operations. It enables us to model specific threat scenarios against our network architecture, develop targeted detection rules for our SIEM, and validate controls through adversary emulation. This threat-informed approach ensures our defences address real-world attack patterns relevant to consulting firms.

Integrated Approach

This hybrid model satisfies all stakeholder requirements: business alignment (CEO/CFO), operational resilience (COO), governance and usability (HR), and both policy-driven and threat-aware controls (Compliance). NIST CSF provides the "what" (outcomes to achieve), while MITRE ATT&CK provides the "how" (specific threats to defend against). Together, they create a comprehensive, mature security program positioned for certification and operational excellence.

Midsize Professional Services Firm



4. Complete DHCP Configuration Table

VLAN ID	VLAN Name	Subnet	Gateway IP	DHCP Server IP	DHCP Scope (Start - End)	Usable IPs	Current Usage	Lease Time	DNS Servers	Notes
5	DMZ	10.5.0.0/24	10.5.0.1	10.0.0.40-49	Static IPs Only	19	15 servers	N/A	10.5.0.2, 10.5.0.3	No DHCP - All static assignments
10	Management	10.0.0.0/24	10.0.0.1	10.0.0.40-49	Static IPs Only	64	~60 servers	N/A	10.0.0.30-39	No DHCP - Static IPs only
21	Project Delivery	10.21.0.0/25	10.21.0.1	10.0.0.40-49	10.21.0.10 - 10.21.0.99	90	35 users	24 hours	10.0.0.30-39	Department workstations
22	Sales/Customer Success	10.22.0.0/25	10.22.0.1	10.0.0.40-49	10.22.0.10 - 10.22.0.99	90	20 users	24 hours	10.0.0.30-39	Department workstations
23	Product/Engineering	10.23.0.0/25	10.23.0.1	10.0.0.40-49	10.23.0.10 - 10.23.0.99	90	15 users	24 hours	10.0.0.30-39	Department workstations
24	Finance & Admin	10.24.0.0/24	10.24.0.1	10.0.0.40-49	10.24.0.10 - 10.24.0.99	90	10 users	24 hours	10.0.0.30-39	Department workstations
25	HR & People Ops	10.25.0.0/25	10.25.0.1	10.0.0.40-49	10.25.0.10 - 10.25.0.49	40	5 users	24 hours	10.0.0.30-39	Department workstations
26	IT & Security	10.26.0.0/25	10.26.0.1	10.0.0.40-49	10.26.0.10 - 10.26.0.49	40	5 users	24 hours	10.0.0.30-39	Department workstations
27	Executive/Leadership	10.27.0.0/26	10.27.0.1	10.0.0.40-49	10.27.0.10 - 10.27.0.49	40	10 users	24 hours	10.0.0.30-39	Executive devices
28	Conference Rooms	10.28.0.0/24	10.28.0.1	10.0.0.40-49	10.28.0.10 - 10.28.0.49	40	10 rooms	4 hours	10.0.0.30-39	Shorter lease for transient devices
30	Internal Servers	10.30.0.0/23	10.30.0.1	10.0.0.40-49	Static IPs Only	50	50 servers	N/A	10.0.0.30-39	No DHCP - Static IPs only
40	Printers	10.40.0.0/24	10.40.0.1	10.0.0.40-49	10.40.0.10 - 10.40.0.149	140	15 devices	7 days	10.0.0.30-39	Printers + print servers
50	Guest WiFi	10.50.0.0/23	10.50.0.1	10.50.0.3	10.50.0.10 - 10.50.1.200	~490	50-100 guests	4 hours	10.50.0.2	Isolated guest network
60	IoT Devices	10.60.0.0/24	10.60.0.1	10.0.0.40-49	10.60.0.10 - 10.60.0.149	140	120 devices	30 days	10.0.0.30-39	Cameras, sensors, HVAC
70	VoIP	10.70.0.0/24	10.70.0.1	10.70.0.200-201	10.70.0.10 - 10.70.0.129	120	120 devices	7 days	10.0.0.30-39	VoIP phones & infrastructure
80	Storage	10.80.0.0/24	10.80.0.1	10.0.0.40-49	Static IPs Only	25	25 servers	N/A	10.0.0.30-39	No DHCP - Static IPs only
90	Quarantine	10.90.0.0/24	10.90.0.1	10.0.0.40-49	10.90.0.10 - 10.90.0.249	240	2-5 devices	2 hours	10.0.0.30-32	Restricted access

5. Hardware - Software Inventory List

1. ALL HARDWARE WITH IP ADDRESSES

1.1 Edge Firewalls (4 units)

Device	Hardware Model	IP Address	Role	Specs
NET-001	Supermicro SYS-5019C-M	10.0.0.100	Primary Active Firewall	E-2276G 6-core, 32 GB DDR4 ECC, 4x Intel i350 1G NIC
NET-002	Supermicro SYS-5019C-M	10.0.0.101	Secondary Active Firewall	E-2276G 6-core, 32 GB DDR4 ECC, 4x Intel i350 1G NIC
NET-003	Supermicro SYS-5019C-M	10.0.0.102	Load Balance/Geo-redundant	E-2276G 6-core, 32 GB DDR4 ECC, 4x Intel i350 1G NIC
NET-004	Supermicro SYS-5019C-M	10.0.0.103	Cold Standby/DR	E-2276G 6-core, 32 GB DDR4 ECC, 4x Intel i350 1G NIC

1.2 Core L3 Switches (8 units)

Device	Hardware Model	IP Address	Role	Specs
NET-010	Aruba 6300M 48G	10.0.0.120	Stack Master	48x 1G PoE++, 4x 10G SFP+, 370W PoE budget
NET-011	Aruba 6300M 48G	10.0.0.121	Stack Member	48x 1G PoE++, 4x 10G SFP+, 370W PoE budget
NET-012	Aruba 6300M 48G	10.0.0.122	Stack Member	48x 1G PoE++, 4x 40G QSFP+, 370W PoE budget
NET-013	Aruba 6300M 48G	10.0.0.123	Stack Member	48x 1G PoE++, Stacking, 370W PoE budget
NET-020	Aruba 6300M 48G	10.0.0.124-127	Redundant Stack (4 units)	48x 1G PoE++

1.3 Distribution L3 Switches (6 units)

Device	Hardware Model	IP Address	Role	Specs
NET-030	Aruba 6200F 24G	10.0.0.130-132	Distribution Layer (3 units)	24x 1G, 4x 10G SFP+, L3 routing
NET-031	Aruba 6200F 24G	10.0.0.133-135	Redundant Distribution (3 units)	24x 1G, 4x 10G SFP+

1.4 Access L2 Switches (19 units)

Device	Hardware Model	IP Address	Role	Specs
--------	----------------	------------	------	-------

NET-040	Aruba 2930F 24G PoE+	10.0.0.140-168	Access Layer (19 units)	24× 1G PoE+, 4× 1G/10G SFP+ uplink, 370W PoE budget
---------	----------------------	----------------	-------------------------	---

1.5 Wi-Fi Controllers & Access Points

User Wi-Fi Infrastructure

Device	Hardware Model	IP Address	Role	Specs
NET-050	Aruba 7005 Controller	10.0.0.160	Primary Controller	Supports 1024 APs, 8K clients, HA-ready
NET-051	Aruba 7005 Controller	10.0.0.161	Secondary/HA Controller	Supports 1024 APs, 8K clients, HA
NET-060	Aruba AP-635 (WiFi 6E)	Various	Office coverage (15-20 units)	802.11ax, 2.5 Gbps uplink, PoE+

Guest Wi-Fi Infrastructure

Device	Hardware Model	IP Address	Role	Specs
NET-080	Aruba 7005 Controller	10.50.0.160	Primary Guest Controller	Supports 1024 APs, 8K clients, HA-ready
NET-081	Aruba 7005 Controller	10.50.0.161	Secondary/HA Guest Controller	Supports 1024 APs, 8K clients, HA
NET-090	Aruba AP-635 (WiFi 6E)	Various	Guest coverage (5-10 units)	802.11ax, 2.5 Gbps uplink, PoE+

1.6 UPS & Power Infrastructure

Device	Hardware Model	Power Redundancy	Role	Specs
PWR-001	APC Smart-UPS SRT 6000VA	Power Management	Primary UPS (2 units)	6 kVA, 230V, Network card, 2U rack
PWR-002	APC Smart-UPS SRT 3000VA	Power Management	Edge UPS (4 units)	3 kVA, 230V, Network card, 2U rack
PWR-003	APC NetBotz 200	Power Management	Environmental Monitoring (1 unit)	Temperature, humidity monitoring

1.7 Physical Hypervisor Hosts (15 servers)

Device	Hardware Model	IP Address/VLAN	Role	Specs
SRV-HV-001	Dell PowerEdge R650	VLAN 10/30	Hypervisor	2× Xeon Gold 6338, 256 GB DDR4 ECC, 4× 10G NIC, 8× 2TB NVMe
SRV-HV-002	Dell PowerEdge R650	VLAN 10/30	Hypervisor	2× Xeon Gold 6338, 256 GB DDR4 ECC, 4× 10G NIC, 8× 2TB NVMe
SRV-HV-003	Dell PowerEdge R650	VLAN 5 (DMZ)	Hypervisor	2× Xeon Gold 6338, 256 GB DDR4 ECC, 4× 10G NIC, 6× 2TB NVMe
SRV-HV-004	Dell PowerEdge R640	VLAN 80 (Storage)	Hypervisor	2× Xeon Silver 4314, 128 GB DDR4 ECC, 4× 10G NIC, 4× 2TB NVMe
SRV-HV-005-015	HPE ProLiant DL360 Gen10+	Various VLANs	Additional Compute (10 units)	Various configs: Xeon Silver/Gold, 64-256GB RAM, 2-4× 10G NIC

1.8 Storage Infrastructure (26 units)

Ceph Storage Cluster

Device	Hardware Model	IP Address	Role	Specs
STOR-001	Dell PowerEdge R740xd	10.80.0.10-29	Ceph Storage Nodes (20 units)	2× Xeon Silver 4314, 128 GB RAM, 24× 8TB SAS (192 TB raw each)

NAS/File Storage

Device	Hardware Model	IP Address	Role	Specs
STOR-010	TrueNAS Mini XL+	10.80.0.100-119	NAS Storage (3 units)	Xeon D-2146NT, 128 GB ECC, 8× 20TB SATA (160 TB raw each)

iSCSI Targets

Device	Hardware Model	IP Address	Role	Specs
STOR-020	Dell PowerEdge R640	10.80.0.150-169	iSCSI Storage (2 units)	2× Xeon Silver 4314, 64 GB RAM, 4× 2.5TB NVMe (10 TB raw each)

Tape Archival

Device	Hardware Model	Location	Role	Specs
STOR-030	IBM TS3200 Tape Library	Physical Server Room	Tape Backup (1 unit)	LTO-8, 48 slots, dual drives (432 TB capacity)

1.9 Backup Infrastructure (6 units)

Device	Hardware Model	IP Address/Location	Role	Specs
Backup Servers	Dell PowerEdge R640	VLAN 80	Backup Servers (5 units)	32 TB each
AWS S3 Glacier	Cloud Service	Internet	Cloud Backup (1 account)	Unlimited capacity

1.11 End-User Devices (220 devices)

Device Type	Quantity	IP Range	Notes
Windows Workstations	55	VLANs 21-28	Windows 10/11 Pro
macOS Workstations	10	VLANs 21-28	Executive devices
Linux Workstations	35	VLANs 21-28	Developer/IT staff
VoIP Phones	120	10.60.0.10-129	IP phones

1.12 Printers (15 units)

Device Type	Quantity	IP Range	Notes
Network Printers	13	VLAN 30	Various departments
Print Servers	2	VLAN 30	Central print management

1.13 IoT Devices (120 units)

Device Type	Quantity	IP Range	Notes
Security Cameras	30	10.70.0.10-39	Surveillance
Access Control	20	10.70.0.40-59	Door/badge readers
HVAC Controllers	20	10.70.0.60-79	Climate control
Other IoT	50	10.70.0.80-149	Sensors, monitors

2. ALL SOFTWARE INVENTORY

2.1 Operating Systems

Software	Version	Quantity	License Type	Use Case
Ubuntu Server 22.04 LTS	22.04	120+	Free (Open Source)	Primary server OS
Debian	12	20+	Free (Open Source)	Secondary server OS
CentOS Stream	9	10	Free (Open Source)	Specific applications
Proxmox VE	8.x	15	Free (Open Source)	Hypervisor platform
Windows 10/11 Pro	10-Nov	55	Commercial (OEM/VL)	User workstations
Windows Server	14-Jul	5	Commercial	AD, File servers
macOS	Sonoma	10	Commercial (Apple)	Executive workstations

Total OS Licenses: 235+

2.2 Network & Security Software

Software	Version	Quantity	License Type	Purpose
pfSense Community Edition	2.7.x	4	Free (Open Source)	Firewall/Router
Cloudflare One	Current	1	Commercial (Cloud)	ZTNA, SWG, CASB
Wazuh	4.7+	1 platform	Free (Open Source)	EDR/XDR platform
Wazuh Agent	4.7+	160+	Free (Open Source)	Endpoint protection
Elasticsearch	8.x	5 nodes	Free (Open Source)	SIEM backend
Kibana	8.x	3 nodes	Free (Open Source)	SIEM dashboard
Logstash	8.x	4 nodes	Free (Open Source)	Log ingestion
Filebeat	8.x	160+	Free (Open Source)	Log forwarding
Elastic Agent	8.x	160+	Free (Open Source)	Fleet-managed monitoring
Snort	3.x	Inline	Free (Open Source)	IPS (inline prevention)
Suricata	7.x	Mirror	Free (Open Source)	IDS (detection)
LibreNMS	Latest	1	Free (Open Source)	Network monitoring
Oxidized	0.29+	1	Free (Open Source)	Network config backup
OpenCTI	5.x	2 nodes	Free (Open Source)	Threat intelligence
pfBlockerNG	Latest	4	Free (Open Source)	DNS filtering, geo-blocking
Duo MFA	Current	100+ users	Commercial	Multi-factor authentication
OpenVPN	2.6+	2 servers	Free (Open Source)	VPN server (HA)
ModSecurity	3.x	2	Free (Open Source)	Web Application Firewall
FreeRADIUS	3.x	1	Free (Open Source)	802.1X authentication

Total Network/Security Software: 19 applications

2.3 Web & Application Servers

Software	Version	Quantity	License Type	Purpose
Nginx	1.24+	10+	Free (Open Source)	Web server, reverse proxy

Apache HTTP Server	2.4+	4	Free (Open Source)	Web server
HAProxy	2.8+	4	Free (Open Source)	Load balancer
Kong Gateway OSS	3.x	4	Free (OSS Edition)	API gateway

Total Web/App Servers: 4 applications

2.4 Database Software

Software	Version	Quantity	License Type	Purpose
PostgreSQL	16.x	10	Free (Open Source)	Primary database
MySQL	8.0+	6	Free (Open Source)	Legacy applications
Redis	7.x	4	Free (Open Source)	Caching, session storage

Total Database Software: 3 applications

2.5 Email Stack

Software	Version	Quantity	License Type	Purpose
Postfix	3.7+	2	Free (Open Source)	SMTP server (MTA)
Dovecot	2.3+	2	Free (Open Source)	IMAP/POP3 server
Rspamd	3.x	1	Free (Open Source)	Anti-spam filtering

Total Email Software: 3 applications

2.6 Development & DevOps

Software	Version	Quantity	License Type	Purpose
GitLab CE	16.x	2	Free (Open Source)	Git repository, CI/CD
Harbor	2.9+	2	Free (Open Source)	Docker registry
Ansible AWX	Latest	1	Free (Open Source)	Configuration management
Terraform	1.6+	1	Free (Open Source)	Infrastructure as code
Docker	24.x	20+	Free (Open Source)	Containerization

Total DevOps Software: 5 applications

2.7 Monitoring & Analytics

Software	Version	Quantity	License Type	Purpose
Prometheus	2.48+	1	Free (Open Source)	Metrics collection
Grafana	10.x	1	Free (Open Source)	Dashboards & visualization
Grafana Loki	2.9+	1	Free (Open Source)	Log aggregation
Apache Superset	3.x	2	Free (Open Source)	Business intelligence

Total Monitoring Software: 4 applications

2.8 Storage & Backup Software

Software	Version	Quantity	License Type	Purpose
----------	---------	----------	--------------	---------

Ceph	Quincy 17.x	20 nodes	Free (Open Source)	Distributed storage
TrueNAS SCALE	23.x	3	Free (Open Source)	NAS storage
Open-iSCSI	Latest	2	Free (Open Source)	iSCSI targets
Bacula	13.x	3	Free (Open Source)	Backup software

Total Storage/Backup Software: 4 applications

2.9 VoIP Software

Software	Version	Quantity	License Type	Purpose
FreePBX	16.x	2	Free (Open Source)	PBX system
Asterisk	20.x	2	Free (Open Source)	VoIP engine

Total VoIP Software: 2 applications

2.10 Core Network Services

Service	Software	Version	Quantity	Purpose
DNS	BIND / PowerDNS	9.18+ / 4.8+	5	Name resolution
DHCP	ISC DHCP / Kea	4.4+ / 2.4+	3	IP address assignment
NTP	Chrony	4.x	3	Time synchronization
RADIUS	FreeRADIUS	3.2+	1	802.1X authentication
LDAP/AD	Samba AD	4.19+	4	Directory services
Certificate Authority	OpenSSL / EJBCA	3.x / 7.x	2	Internal PKI

Total Network Services: 6 services

2.11 Guest Network Software

Software	Version	Quantity	License Type	Purpose
PacketFence	Latest	1	Free (Open Source)	Captive portal for guest WiFi

6. Network Risk Assessment & Control Mapping

Top 3 Network Risks with NIST CSF 2.0 Framework Controls

RISK #1: MISCONFIGURATION

Risk Description

Network device misconfigurations (firewalls, switches, routers) leading to unauthorized access, service disruption, or security policy bypass.

Threat Scenarios:

1. Administrator accidentally deletes critical firewall rule → Network outage
2. Switch misconfigured during VLAN change → Guest network accesses corporate data
3. Default SNMP community string "public" left enabled → Unauthorized monitoring
4. Telnet enabled on switches → Credentials transmitted in clear text
5. Incorrect ACL allows DMZ-to-Internal traffic → Lateral movement after breach

Controls Implemented:

Function	Control	Implementation
GOVERN	Change Management (FR-021)	IT lead + Security approval, documented in ITSM

GOVERN	Hardening Policy (FR-034)	CIS Benchmarks for all devices
IDENTIFY	Asset Inventory (FR-047)	LibreNMS tracks all 36 devices, version tracking
IDENTIFY	Vulnerability Mgmt (FR-033)	OpenVAS monthly scans, 7-day critical patch SLA
PROTECT	Config Baseline (FR-022)	Oxidized daily backups, 90-day retention
PROTECT	Change Control (FR-021)	Version control, pre/post snapshots, rollback testing
DETECT	Monitoring (FR-018)	LibreNMS real-time alerts < 5 min
DETECT	Config Drift Detection (FR-032)	Wazuh FIM on configs, Slack webhooks
RESPOND	Network Forensics (FR-046)	NetFlow 90-day retention, packet capture 7-day
RESPOND	Incident Response (FR-022)	4-hour RTO, documented rollback procedures
RECOVER	Backup & Restore (FR-022)	NAS + EU cloud, monthly restore tests

RISK #2: UNAUTHORIZED ACCESS

Risk Description

Unauthorized users (external attackers, ex-employees, compromised credentials) gaining access to internal network resources, sensitive data, or critical systems.

Threat Scenarios:

1. Attacker steals VPN credentials via phishing → Full internal network access
2. Terminated employee still has active VPN → Data exfiltration after departure
3. Contractor plugs unauthorized device into ethernet port → Rogue device on network
4. Guest cracks shared Wi-Fi password → Access to corporate resources
5. Lateral movement from DMZ to Internal VLAN → Ransomware spreads
6. Ex-employee uses old admin credentials → System sabotage

Controls Implemented:

Function	Control	Implementation
GOVERN	RBAC Policy (FR-026, FR-037)	5 VPN profiles with least privilege
IDENTIFY	Device Inventory (FR-036)	NAC tracks all devices, quarantine VLAN for unknowns
IDENTIFY	Network Documentation (FR-041)	16 VLANs with documented firewall policies
PROTECT	MFA (FR-025, FR-037)	Duo MFA for VPN, jump box, admin access
PROTECT	Certificate Auth (FR-048)	802.1X EAP-TLS for wired/wireless
PROTECT	NAC (FR-036, FR-048)	FreeRADIUS 802.1X, device health checks
PROTECT	Rapid Offboarding (FR-027)	Automated workflow, < 1 hr revocation target
PROTECT	Encryption (FR-028)	AES-256-GCM VPN, TLS 1.3 minimum
PROTECT	Segmentation (FR-003, FR-041)	Zero-trust VLANs, DMZ isolated
DETECT	Auth Monitoring (FR-032)	Failed login alerts (5 attempts in 5 min)
DETECT	EDR (FR-010)	Wazuh agents on 160+ endpoints

DETECT	SIEM Correlation (FR-038)	Wazuh + ELK, multi-source correlation
DETECT	Audit Logging (FR-030)	12–18 month retention, WORM storage
RESPOND	Incident Response (FR-027)	Automated account disable, VPN session termination
RESPOND	Investigation (FR-018)	PagerDuty + Slack, 5-min detection target
RECOVER	DR (FR-022)	Account restoration procedures, post-incident review

RISK #3: INSIDER THREAT (Malicious or Negligent)

Risk Description

Authorized users (employees, contractors, partners) intentionally or accidentally causing security incidents through data exfiltration, sabotage, or negligent actions.

Threat Scenarios:

1. Disgruntled employee downloads all client data before resignation
2. IT admin shares VPN credentials with external consultant
3. Employee accidentally configures public share for sensitive HR folder
4. IT admin deliberately deletes backups and critical configurations
5. Employee falls for CEO fraud email, transfers €50K to attacker
6. Contractor uploads company IP to personal Dropbox account

Controls Implemented:

Function	Control	Implementation
GOVERN	Risk Management (FR-006)	€7,500/hour outage cost calculated, controls justified
GOVERN	Compliance (FR-028, FR-031)	GDPR, ISO 27001 (in progress), SOC 2 (planned)
IDENTIFY	Threat Intel (FR-045)	OpenCTI with MITRE ATT&CK insider threat tactics
IDENTIFY	Vendor Management (FR-029)	DPA's, SCCs, vendor security assessments
PROTECT	Access Reviews (FR-026, FR-027)	Quarterly privileged, annual all users
PROTECT	Data Encryption (FR-016)	At-rest: LUKS/ZFS, At-transit: TLS/VPN
PROTECT	Data Retention (FR-030)	12–18 month policy, secure disposal (3-pass wipe)
PROTECT	Secure Development (VLAN 30)	GitLab code review, 4-eyes production deployment
DETECT	SOC Alerting (FR-018)	PagerDuty + Slack, tiered alerts (P1/P2/P3)
DETECT	Malware Detection (FR-010)	Wazuh real-time scanning, FIM, behavioural analysis
DETECT	User Behaviour Analytics (FR-030, FR-035)	VPN logs, file access, database queries, email
DETECT	Network Forensics (FR-046)	Packet capture 7-day, NetFlow 90-day
RESPOND	Vulnerability Mgmt (FR-033)	OpenVAS monthly, 7-day critical patch SLA
RESPOND	Investigation Logging (FR-030)	WORM (Write Once, Read Many) storage, chain of custody, forensic exports
RESPOND	Incident Reporting (FR-028)	GDPR 72-hour notification, client procedures
RECOVER	Reputation Mgmt (FR-028)	Pre-drafted templates, legal review process
RECOVER	DR (FR-022)	4-hour RTO, monthly testing, lessons learned

Framework Implementation:

NIST CSF 2.0: 35+ controls across all 6 functions (Govern, Identify, Protect, Detect, Respond, Recover)

MITRE ATT&CK: Threat modelling for insider tactics

Requirements: 48 functional requirements (FR-001 through FR-048)

Defence-in-Depth Layers:

1. **Perimeter:** pfSense HA firewalls + dual ISP
2. **Network:** 16 VLANs with zero-trust segmentation
3. **Access:** MFA + 802.1X NAC + certificate auth
4. **Endpoint:** Wazuh EDR on 160+ devices
5. **Application:** WAF + API gateway + secure coding
6. **Data:** Encryption at-rest/transit + access logging
7. **Monitoring:** SIEM + EDR + network forensics + threat intel
8. **Process:** Change management + access reviews + IR playbooks

Document Owner: IT & Security Team

Prepared by: Prageeth Panicker

Approved By: